

BioPrint — behaviour-based login: how it works

ROOT 36, Event 2. Setup and demo commands: `code/bioprint/README.md`.

1. What it does

BioPrint is a website login that checks *how* the password is typed, not only *what*: every attempt is scored against an enrolled rhythm profile and a mismatch is **blocked**, with no OTP or second factor. Scripts, headless browsers and replayed recordings are caught by a separate bot signal, and a changed device is recognised from ~30 browser attributes. Every decision carries a plain-English reason and takes under 130 ms.

2. Signals captured (browser → FastAPI + SQLite)

Channel	Vector	Source
Keystroke	3k–2 numbers for a k-key password: k hold times (H), k–1 down-down gaps (DD), k–1 up-down gaps (UD), in ms. Same layout as the CMU benchmark, so one scorer serves both.	<code>capture.js</code> , <code>features.py</code>
Pointer	14 features of the final reach-and-click on the button: Fitts slope, path efficiency, curvature, velocity-profile shape, corrective sub-movements, overshoot, landing offset, hover/settle/hold times; distance-normalised.	<code>pointer.js</code> , <code>pointer.py</code>
Environment	32 attributes: <code>navigator.webdriver</code> , automation globals, UA and client hints, fonts, screen, canvas/audio/WebGL hashes, languages, timezone, hardware counts, permissions.	<code>probe.js</code>

Only `event.code` (the physical key) is recorded, never the character. Modifiers are excluded; a Backspace breaks positional alignment, so that attempt is retyped rather than scored. Firefox’s phantom duplicate keydowns (~1% of events) are collapsed to the later press.

3. Core algorithm

Enrollment. One practice repetition (stored, not counted) plus 10 counted typings. The profile is, per feature, the **median** of the 10 and the **mean absolute deviation** about it, floored (5% of |centre|, 15% of the family’s median spread, 10^{-6}) so a coincidentally constant feature cannot dominate.

Scoring. Scaled Manhattan (Killourhy & Maxion, DSN 2009: strongest of 14 detectors, and still hard to beat at small n): $\text{score} = \text{mean over features of } |x - \text{median}| / \text{spread}$, each term **capped at 6**. The mean keeps the unit “typical deviations” comparable across password lengths and channels; each feature’s share becomes a reason (“held ‘L’ 88 ms longer than usual”).

Threshold. Per user by leave-one-out: each enrollment sample is scored against the other nine; $\text{threshold} = 1.5 \times \text{the 75th percentile of those distances}$, **clipped to [1.0, 1.9]**. Honestly: at n=10 the raw rule exceeds 1.9 for 95% of CMU subjects (median 2.17), so 1.9 is the population operating point; the per-user part binds only as the profile grows.

Decision (`decide.py`). Signals are never summed into one number; the *disagreement pattern* is the information.

Bot	Keystroke	Device	Decision
flagged	—	—	block : automated or replayed input
clear	score > threshold	any	block , listing the top deviating features
clear	ok	same	allow
clear	ok	different (> 6 bits)	step-up : 3 more typings; the median of all 4 scores decides. Same modality, no OTP.

Pointer is advisory: one channel on 10 samples is too noisy to veto the keystroke verdict.

4. Bot and replay detection (`bot.py`)

Rule weights add up; flagged above 0.75. **Strong** (1.0, block alone): `isTrusted=false`, `navigator.webdriver`, driver globals, `HeadlessChrome`, fewer key presses than password characters, any hold under 10 ms (faster than a key switch travels), over half the DD gaps under 10 ms, intervals identical within 0.5 ms, timing coefficient of variation < 0.03 (humans 0.2–0.6; browser jitter alone gives 0.01–0.03), a pointer teleport > 150 px into the click. **Weak** (0.15–0.5, must stack): software GL renderer, zero-size window, missing plugins or `window.chrome`, contradictory permissions, timings on a 10 ms grid, click without prior movement.

Replay: mean absolute difference over all H/DD/UD features against every stored sample of the user; < 4 ms is a replay. The tolerance comes from data: over ~4M same-subject pairs in CMU, the closest two repetitions any subject ever produced differ by 4.74 ms MAE (median subject 7.9 ms), while a replayed recording adds only 1 ms timer quantisation plus the 2.8 ms p95 delivery jitter we measured. Fuzzing every timestamp by ± 10 ms clears this rule and falls to the keystroke scorer.

5. Device axis (device.py)

Panoptick turned around: Eckersley (2010) and Laperdrix et al. (2016, AmIUnique) measured how many bits of identity each browser attribute carries; we use those bits as **evidence weights** for attributes that *differ* from the enrollment majority (fonts 13.9, languages 5.9, canvas 5.0, screen 4.8, GPU 3.4, ...; ≈ 56 bits in all). Nothing is hashed into one ID. A browser version bump costs 0.5 bits, an update plus a new canvas hash 5.5, a new monitor 5.3; a different laptop moves 20–30+. The flag sits at **6 bits**.

6. Reliability

CMU dataset (Killourhy & Maxion 2009: 51 subjects $\times$ 400 reps of .tie5Roan1, 8 sessions on different days); python -m eval.cmu, run eval/results/cmu-20260919-153251.json:

Protocol	EER	FRR @ FAR 5%	FRR @ FAR 1%	FRR / FAR at threshold
P1, published setup: 200 reps, sessions 1–4 $\rightarrow$ 5–8	6.9% (K&M: 9.6%)	11.3%	29.9%	3.1% / 17.7%
P2, product setup: 10 reps of session 1 $\rightarrow$ sessions 2–8	20.2%	51.6%	73.8%	21.6% / 26.2%
P2, fluent enrollee: last 10 reps of session 4 $\rightarrow$ 5–8	10.7%	23.3%	41.7%	29.8% / 8.0%
P2 sweep, 5 / 10 / 20 / 50 enrollment reps	25.6 / 20.2 / 15.6 / 11.8%			

EER hides which side an error lands on; FRR at fixed FAR is the number to read, and it says that **a low-FAR operating point is not reachable from 10 keystroke samples alone**: a constant threshold calibrated to FAR 5% (≈ 1.3) costs 72% FRR cross-session, and 92% at FAR 1%. Hence separate bot and device nets, and more typing on a new device rather than a lower threshold.

Weighted average? (eval/weights.py, cross-fitted on subject halves.) Family weights H/DD/UD $\approx 1.5/1.5/0.5$ gain only +0.6–0.8 EER points (20.2 $\rightarrow$ 19.6%), under the 1-point bar; per-feature Fisher weights overfit at 25 subjects (21.4%). Flight time (UD) is the least informative family. The plain mean shipped.

Live (one subject, own laptop, server time): every decision 77–126 ms. Owner allowed at 0.89 and 1.75 vs limit 1.9; owner typing deliberately slowly blocked at 4.68; owner typing a bot-enrolled account’s password blocked at 5.8 vs limit 1.0 (a metronome profile hits the threshold floor). 9 bot/replay attacks, 9 blocked: naive scripts by the bot rules (webdriver, HeadlessChrome, 5 ms holds, identical intervals); a careful gaussian-timing script passed the bot rules and was caught by the keystroke score (3.1 and 5.5 vs 1.9); replays at 0.00 ms MAE; a headless Chromium driving the real page blocked (timing CV 0.013).

7. Latency

Profile fit 1.6 ms for 10 samples (21 ms for the 200-sample CMU protocol, leave-one-out included); scoring 0.04–0.06 ms mean, p95 < 0.1 ms; the whole /api/login (features, bot rules, device, SQLite write) < 130 ms.

8. Limitations and privacy

event.code on the password field spells the password on a QWERTY layout, so bioprint.db effectively stores passwords: a **hackathon-only trade-off**, never to be reused; the research design stores per-user templates, not raw streams. Profiles must be per (user, device class): a desktop template cannot score a phone. Live data is one subject; CMU, where an “impostor” was given the password and practised it five times, is the population evidence. Behavioural data identifying a person is GDPR Art. 9 special-category data.

Demo script. (1) #enroll: type the password 1 practice + 10 times, clicking Login. (2) #login as the owner $\rightarrow$ allowed, ~ 80 ms. (3) A teammate types the correct password $\rightarrow$ blocked, “5.8 vs limit 1.9 — held ‘L’ 88 ms longer than usual”. (4) attacks/scripted.py --mode fixed $\rightarrow$ bot rules block it; --mode humanlike $\rightarrow$ rhythm blocks it. (5) attacks/replay.py $\rightarrow$ blocked, “matches a stored attempt to within 0.00 ms”. (6) dashboard.html?user=NAME: every attempt, four gauges apart.